
Audit Summary

Control outcome summary and framework alignment overview

Project: Enterprise DevSecOps Security Lab

Author: Jagriti Banerjee

Artifact: audit_summary.md

Assessment Context

Summarizes audit criteria, scope, control results, exceptions, residual risk, recommendations, and portfolio-use opinion.

Confidentiality: Portfolio lab documentation. Compliance mappings are control-alignment artifacts only and are not formal certifications, attestations, or legal compliance opinions.

1. Executive Audit Summary

The Enterprise DevSecOps Security Lab demonstrates an end-to-end secure delivery lifecycle across application security, dependency analysis, container hardening, Kubernetes security, GitOps, supply-chain integrity, runtime detection, observability, risk management, and audit documentation. This audit summary consolidates control outcomes and maps evidence to requested frameworks.

Overall audit conclusion: the lab shows strong evidence of security engineering maturity for a portfolio project. The strongest areas are CI/CD security gates, Kubernetes hardening, supply-chain documentation, runtime detection, and professional remediation evidence. Remaining areas are primarily enterprise enhancements: trusted builder provenance, admission-time image signature verification, ticketing integration, and formal compliance attestation.

2. Audit Criteria

Framework / Control Theme	Audit Use	Status
NIST SSDF	Secure software development lifecycle, vulnerability response, and software supply-chain practices	Aligned
OWASP ASVS	Application security verification requirements for Flask app findings and remediation	Aligned
CIS Kubernetes Benchmark	Consensus-based Kubernetes secure configuration guidance and kube-bench validation	Aligned
SLSA	Artifact integrity, provenance, and tamper-resistance checklist	Partially aligned - trusted builder recommended
SOC 2 style controls	Security, change management, monitoring, access control, and risk response themes	Style-aligned only
ISO 27001 style controls	ISMS-style risk treatment, secure configuration, monitoring, and continual improvement	Style-aligned only
PCI/HIPAA alignment only	Secure development, access control, audit logging, segmentation, and risk management themes	Alignment only - no regulated data in scope

3. Audit Scope

- Application: intentionally vulnerable Python Flask app with SQL injection, command injection, unsafe rendering, and dependency risk evidence.
- Pipeline: GitHub Actions workflows for SAST, SCA, Trivy filesystem/config/image scans, security gates, SARIF upload, and Scorecard assessment.
- Container: multi-stage Docker build, non-root execution, Trivy image scanning, Cosign signing, Syft SBOM generation, and provenance attestation.
- Kubernetes: Kind cluster with hardened manifests, RBAC, NetworkPolicy, Pod Security, Gatekeeper policy-as-code, and kube-bench-style assessment.
- GitOps: ArgoCD sync, prune, self-heal, and drift correction evidence.
- Runtime security: Falco, Falcosidekick, Prometheus rules, Grafana dashboard, incident response runbook, and detection report.
- Governance: risk register, exceptions, VEX notes, retest proof, evidence index, and compliance mapping.

4. Control Outcome Summary

Control Area	Assessment Result	Evidence Reviewed	Audit Notes
Secure SDLC and AppSec	Effective for lab scope	Bandit, AppSec test cases, OWASP mapping, finding reports	Application vulnerabilities were identified, documented, remediated, and retested.
Dependency Security	Effective with accepted risk workflow	pip-audit summary, dependency finding, SBOM	Vulnerable packages are visible; critical dependencies should fail gates or require exception.
Container Security	Effective	Dockerfile, Trivy image scan, non-root evidence	Image hardening controls are documented and validated.
Supply Chain Security	Strong for portfolio lab	Cosign verify, Syft SBOM, provenance summary	Full SLSA compliance requires trusted builder provenance and stronger admission enforcement.
Kubernetes Security	Effective	Kubernetes assessment, RBAC review, NetworkPolicy validation, Pod Security validation	Least privilege, segmentation, pod hardening, and admission controls are demonstrated.
Runtime Detection	Effective	Detection report, Falco rule analysis, Grafana dashboard, Prometheus rules	Detection logic includes trigger, triage, response, and evidence.
Audit Governance	Effective for portfolio lab	Control validation matrix, risk register, audit summary	Evidence is mapped, risk-based, and ready for recruiter/security review.

5. Key Strengths

- Evidence-first documentation: each major control has screenshot, report, or command output evidence.
- End-to-end DevSecOps flow: vulnerable app to scanning, remediation, containerization, Kubernetes deployment, GitOps, and monitoring.
- Enterprise-style supply-chain artifacts: image digest, Cosign verification, SBOM package counts, provenance, VEX notes, and exception tracking.
- Kubernetes security depth: RBAC, NetworkPolicy, Pod Security, Gatekeeper, kube-bench-style assessment, and Falco runtime detection.
- Operational response readiness: detection report, Prometheus rules, Grafana dashboard, and incident response runbook.

6. Exceptions and Residual Risk

Exception	Reason	Compensating Control	Residual Risk
Local lab SLSA-style provenance	Generated in private VM, not a trusted builder attestation	Cosign attestation, commit reference, image digest recorded	Medium
Intentionally vulnerable app branch	Required for teaching and evidence demonstration	Reports clearly mark lab-only vulnerable routes; remediation examples included	Medium
Admission-time image signature enforcement not implemented	Cosign verification performed manually/CI but not enforced by Kubernetes admission	Gatekeeper labels, Cosign verify evidence, recommendation for Kyverno/Sigstore policy controller	Medium
SOC 2/ISO/PCI/HIPAA not formally audited	Portfolio lab cannot provide formal attestation or regulated-data validation	Alignment-only mapping and audit disclaimer	Low

7. Priority Recommendations

Priority	Recommendation	Expected Improvement
P1	Add admission-time signature verification using Kyverno verifyImages or Sigstore Policy Controller.	Moves image signing from evidence-only to enforceable deployment control.
P1	Use GitHub Actions trusted build provenance and attach provenance to GHCR artifacts.	Improves SLSA alignment and build traceability.
P2	Make security-gates.yml a required branch protection check.	Prevents critical dependency, container, secret, Dockerfile, and Kubernetes misconfigurations from merging.
P2	Integrate Falco alerts into Slack/Jira or ticketing workflow.	Improves response speed and accountability.
P3	Maintain quarterly risk register and exception review cycle.	Prevents stale accepted risks and improves audit readiness.

8. Audit Opinion for Portfolio Use

Based on available evidence, the Enterprise DevSecOps Security Lab demonstrates practical, hands-on competence in secure SDLC, CI/CD security, Kubernetes hardening, supply-chain security, detection engineering, and risk-based documentation. It is suitable for portfolio presentation and technical interview discussion. It should not be represented as a formal SOC 2, ISO 27001, PCI DSS, HIPAA, or CIS certification.

References and Alignment Sources

The following references were used as control-alignment sources. The PCI and HIPAA mappings in this portfolio lab are alignment-only and do not represent formal compliance validation, attestation, or certification.

Source	Reference	Use in this document
NIST SSDF	NIST SP 800-218 SSDF v1.1	Secure software development practices used as SDLC control baseline.
OWASP ASVS	OWASP ASVS 5.0.0	Technical verification requirements for application security controls.
CIS Kubernetes Benchmark	Center for Internet Security Kubernetes Benchmark	Consensus-based secure configuration guidance for Kubernetes.
SLSA	Supply-chain Levels for Software Artifacts	Framework/checklist for preventing tampering and improving artifact integrity.
SOC 2 style	AICPA Trust Services Criteria	Control themes aligned to security, availability, confidentiality, and processing integrity.
ISO 27001 style	ISO/IEC 27001:2022	Information security management system control alignment.
PCI alignment only	PCI DSS security requirements	Alignment to protection of cardholder-data environments; no PCI validation claimed.
HIPAA alignment only	HIPAA Security Rule	Alignment to administrative, physical, and technical safeguard themes; no HIPAA compliance opinion claimed.